الفصل الثالث: المحافظة على الامتثال

من المتطلبات القانونية إلى السلوك الأمن العملي

مخرجات التعلم

- ربط الامتثال بالحوكمة والمخاطر والضوابط.
- فهم معنى الالتزام بالقوانين واللوائح والمعايير والسياسات.
- تمييز القوانين الأمريكية المؤثرة في تقنية المعلومات.
- معرفة دور الرقابة والتنفيذ وتوقعات الامتثال للجهات التنظيمية.
- تحويل المتطلبات إلى قواعد عملية للمستخدمين والأنظمة عبر السياسات.
- المقارنة بين المعايير والأطر الداعمة للتنفيذ.

مفهوم الامتثال والمصطلحات الأساسية

تعريف الامتثال (Compliance): تحويل المتطلبات الخارجية والداخلية إلى التزام قابل للإثبات، وتقديم الأدلة التي تؤكد أن المؤسسة تعرف متطلباتها وتنفذها كضوابط تقاس وتراجع بانتظام.

المصطلحات الرئيسية

- **القوانين (Laws):** قواعد ملزمة تصدرها السلطات التشريعية في الدولة، وتترتب على مخالفتها عقوبات قانونية وغرامات (مثل: قانون حماية البيانات الشخصية).
- **اللوائح (Regulations):** قواعد تفصيلية تصدرها الجهات الحكومية أو التنظيمية لتوضح وتفسر كيفية تطبيق القوانين عملياً (مثل: لائحة تحدد متطلبات احتفاظ البيانات أو الإبلاغ عن الحوادث).
- **السياسات الداخلية (Internal Policies):** قواعد تضعها المؤسسة لتنظيم عمل الموظفين، حماية الأصول، وضمان تحقيق متطلبات العمل والامتثال (مثل: سياسة كلمات المرور وسياسة التحكم بالوصول).
- **المعايير (Standards):** مواصفات ومتطلبات فنية محددة متفق عليها لتنفيذ أمر معين، وتكون إلزامية أو اختيارية حسب السياق (مثل: ISO/IEC 27001).
- **العقود (Contracts):** اتفاقيات ملزمة قانونياً بين طرفين أو أكثر تحدد الحقوق والالتزامات والمسؤوليات (مثل: عقد الخدمة السحابية المتضمن لضوابط أمن البيانات).

القاعدة التوجيهية للفرق بين المصطلحات:

- **القانون:** يقول ماذا يجب الالتزام به.
- **اللائحة:** تشرح كيفية التطبيق.

- **السياسة:** تحدد ما تريده المؤسسة.
- **المعيار:** يحدد المستوى والطريقة المطلوبة.
- **العقد:** يلزم الأطراف بالتنفيذ.

أهمية الامتثال والفرق بينه وبين الأمن

أهمية الامتثال:

- تجنب الغرامات والعقوبات المالية.
- حماية البيانات الحساسة والمالية.
- تقليل التعرض للمساءلة القانونية.
- بناء الثقة مع العملاء والشركاء.
- تحسين الحوكمة المكتبيّة والتنفيذية.
- دعم وتغذية عملية إدارة المخاطر.

مقارنة: الامتثال ليس هو الأمن

الامتثال (Compliance)	الأمن السيبراني (Security)
السؤال الأساسي: "هل نفذنا المطلوب؟"	**السؤال الأساسي:** "هل نحن محميون فعلاً؟"
يعتمد على الأدلة، السجلات، والمراجعات المطابقة للقانون أو المعيار.	يعتمد على الاختبار الواقعي، تقليل المخاطر الفعلية، ومقاومة التهديدات السيبرانية.

💡 **القاعدة: الامتثال هو الحد الأدنى المقبول وليس الهدف النهائي للحماية.**

القوانين الرئيسية المؤثرة في تقنية المعلومات

تختلف متطلبات الامتثال باختلاف القطاع ونوع البيانات التي يتعامل معها النظام:

قانون FISMA (إدارة أمن المعلومات الفيدرالية)

- يركز على حماية أنظمة ومعلومات الحكومة الأمريكية.
- يعتمد على ضوابط مبنية على المخاطر.
- يتطلب إجراءات الاعتماد والتصديق والمراجعات الدورية المستمرة.

قانون HIPAA (تأمين ومسؤولية التغطية الصحية)

- يختص ببيانات الرعاية الصحية والأنظمة الطبية.
- يفرض حماية بيانات المرضى والأنظمة العلاجية.
- يتطلب المحافظة على السرية والتحكم الصارم في الوصول.
- يتطلب تحليل المخاطر والمراقبة المستمرة للنظام.

قانون GLBA (تحديث الخدمات المالية)

- يستهدف المؤسسات والقطاعات المالية لحماية البيانات المالية للعملاء.
- يعمل على تقليل الإفصاح غير الضروري عن البيانات.
- يفرض تطبيق ضوابط الحماية (Safeguards).
- يدير مشاركة المعلومات ويحفظ ثقة العملاء.

قانون SOX (ساربانس أوكسلي)

- يربط سلامة ودقة التقارير المالية بسلامة الأنظمة التقنية التي تنتجها.
- يتطلب التحكم في الوصول لمنع التلاعب بالسجلات المالية.
- يضمن دقة البيانات ويحدد مسؤولية الإدارة عن التصريحات غير الدقيقة.

قانون FERPA (الخصوصية والحقوق التعليمية للأسرة)

- يحمي السجلات التعليمية (مثل: الدرجات، البيانات التعريفية، سجلات الحضور، والملفات الأكاديمية).
- يحدد الأشخاص المصرح لهم ويمنع الإفصاح غير المصرح به للجهات الخارجية.

قانون CIPA (حماية الأطفال على الإنترنت)

- يركز على أمان الإنترنت في المدارس والمكتبات العامة لحماية القاصرين.
- يتطلب حجب الفلترة للمحتوى الضار وغير اللائق.
- يفرض تطبيق ضوابط تقنية لإدارة بيئة استخدام آمنة.

السياسات التنظيمية وضوابط الحماية

أهمية السياسات التنظيمية: تحويل متطلبات الامتثال إلى قواعد تطبيقية يومية، مع توضيح السلوكيات المقبولة والمسؤوليات وآليات الإبلاغ والتصعيد.

أنواع السياسات الرئيسية:

- **سياسة الاستخدام المقبول:** تحدد كيفية استخدام الموارد الرقمية والشبكات بشكل صحيح.
- **سياسة الأمن:** توضح المبادئ والضوابط العامة لحماية الأصول.
- **سياسة التحكم في الوصول:** تحدد كيف ومن يمكنه الوصول للبيانات والأنظمة.
- **سياسة التعامل مع البيانات:** توضح تصنيف البيانات، تخزينها، ونقلها والتخلص منها.
- **سياسة الإبلاغ عن الحوادث:** تحدد الخطوات وآلية الإبلاغ عند وقوع حادث أمني.

مفهوم العناية الواجبة والتحقق المستمر

- **العناية الواجبة (Due Diligence):** اتخاذ جميع الإجراءات المعقولة لحماية الأصول (مثال: تركيب القفل وإغلاق الباب).
- **التحقق المستمر (Due Care):** المتابعة والتحقق الدوري من أن الحماية تعمل بفاعلية كما ينبغي (مثال: الفحص الدوري للباب والقفل للتأكد من سلامتهما).

> **النتيجة:** حماية موثقة قائمة على أدلة وليس مجرد نوايا حسنة.

ضوابط تقليل الاحتيال وسوء الاستخدام

القاعدة الأساسية: عدم منح شخص واحد القدرة المطلقة على التنفيذ والإخفاء والمراجعة معاً.

الآليات المتبعة:

- تدوير الوظائف (Job Rotation).
- الإجازات الإجبارية (Mandatory Vacations).
- فصل المهام (Separation of Duties).
- منح أقل صلاحية (Least Privilege).
- الاحتفاظ بسجلات التدقيق والمراجعة (Audit Logs).

الأطر والمعايير الدولية

معيار PCI DSS (صناعة بطاقات الدفع)

- ينطبق على أي جهة تخزن أو تعالج أو تنقل بيانات بطاقات الدفع.
- يتطلب بناء شبكات آمنة وحماية بيانات أصحاب البطاقات.
- يفرض إدارة الثغرات وتطبيق تحكم قوي بالوصول.
- يتطلب إجراء مراقبة واختبارات دورية ومستمرة للشبكات.

إطار NIST SP 800-30 (خطوات تقييم وإدارة المخاطر)

1. وصف ومُعايشة النظام (System Characterization).
2. تحديد التهديدات (Threat Identification).
3. تحديد الثغرات والضعف (Vulnerability Identification).
4. تحليل الضوابط المطبقة (Control Analysis).
5. تحديد الاحتمالية والتأثير (Likelihood & Impact Determination).
6. تحديد مستوى الخطر الإجمالي (Risk Determination).
7. التوصية بالضوابط المناسبة (Control Recommendations).
8. توثيق النتائج والتقارير (Results Documentation).

إطار COBIT

يختص بحوكمة وإدارة تقنية المعلومات بناءً على احتياجات ومتطلبات الأعمال.

> **التسلسل العملياتي لـ COBIT:**
> الأهداف والتطلعات تقود الموارد ← العمليات تستخدم الموارد ← المعلومات تدعم وتخدم المؤسسة.

معايير ISO/IEC (مجموعة المواصفات الدولية للضوابط والممارسات)

- **ISO/IEC 27002:** دليل شامل لجميع الضوابط الأمنية الموصى بها.
- **ISO 31000:** المعيار الخاص بإدارة المخاطر المؤسسية.
- **IEC 31010:** الأدوات والتقنيات التفصيلية لتقييم المخاطر.

أطر عمل إضافية:

- **ITIL:** يغطي كامل دورة حياة إدارة خدمات تقنية المعلومات.
- **CMMI:** نموذج نضج يهدف لتقييم وتحسين جودة العمليات والممارسات.

خلاصة الفصل

- الامتثال لا يحل محل الأمن، بل يربط الأمن بالالتزامات القانونية والتجارية ويعزز إدارة المخاطر.
- القوانين تحدد الحماية المطلوبة، اللوائح تنشئ الرقابة، السياسات تحول المتطلبات لسلوك، المعايير والأطر تساعد في التنفيذ، وإدارة المخاطر تربط كل ذلك بمتطلبات القرار.
- يُستخدم الامتثال كقاعدة انطلاق لبناء برنامج أمن معلومات قابل للقياس والتحسين المستمر.